

THREAT MODELING LAB

Attacker Motivation

1. Cybercriminals (external hackers)

- Skill level: medium / high
- Access: external (via the Internet)
- Goals:
 - stealing money (payments, transactions)
 - stealing users' personal data
 - selling data on the black market

2. Competitors

- Skill level: high
- Access: external (sometimes via insiders)
- Goals:
 - obtaining business information
 - disrupting system operations
 - damaging MegaTravel's reputation

3. Internal employees (insiders)

- Skill level: low / medium
- Access: internal (legitimate system access)
- Goals:
 - abusing access privileges
 - stealing customer data
 - sabotage (e.g., deleting data)

4. Regular users (malicious users)

- Skill level: low
- Access: external (via website or application)
- Goals:
 - exploiting the system (e.g., fake bookings)
 - obtaining discounts or refunds illegally

5. Automated bots

- Skill level: low / medium
- Access: external
- Goals:
 - overloading the system (DDoS attacks)
 - password brute forcing
 - sending massive API requests

Conclusion

The MegaTravel system is an attractive target because it:

- contains financial data
- stores users' personal information
- serves a large number of customers

Attack Surface

1. Users interacting with the system

1.1 End users (customers)

- Access the system via:
 - web application (browser)
 - mobile application
- Possible entry points:
 - login and registration forms
 - booking forms
 - payment forms
 - profile management

1.2 Employees (internal users)

- Access the system via:
 - internal dashboards / admin panels
- Possible entry points:
 - admin login interface
 - data management interfaces
 - internal tools

1.3 Third-party services

- Examples:
 - payment gateways
 - external APIs (e.g., transport, hotel providers)
- Possible entry points:
 - API integrations
 - data exchange endpoints

2. System components exposed to interaction

2.1 Web application (frontend)

- Accessible via browser
- Entry points:
 - HTTP/HTTPS requests
 - user input fields (forms)

2.2 Backend API

- Handles business logic and communication
- Entry points:
 - REST API endpoints
 - authentication endpoints
 - booking and payment endpoints

2.3 Database (indirect access)

- Not directly exposed, but reachable via backend
- Risk:
 - SQL injection through API

2.4 Authentication system

- Entry points:
 - login
 - registration
 - password reset

2.5 Payment system integration

- Entry points:

- payment processing endpoints
- callbacks from payment providers

3. Network-level attack surface

- Internet-facing servers
- Open ports (e.g., HTTP/HTTPS)
- Communication between services

Conclusion

The attack surface of the MegaTravel system includes all external interfaces through which users and systems interact with it, especially:

- web and mobile applications
- API endpoints
- authentication mechanisms
- payment integrations

These entry points represent potential vectors for attacks and must be properly secured.